When a service works on behalf of government

The law follows both the information and the work being done. A tenant boundary alone cannot answer who is responsible.

Research checked 24 October 2026; legal editions vary. Source dates and limits

---

The answer

An agency can use a privately run service without taking over the provider's business. It still has to protect federal information, meet applicable requirements, and establish what the provider will do. Commercial ownership and shared infrastructure do not, by themselves, put a service outside those duties.

Two duties, not one

The Federal Information Security Modernization Act (FISMA) gives agency heads a duty to protect information collected or maintained by or on behalf of the agency. It separately covers information systems used or operated by the agency, its contractors, or another organization on its behalf. A conclusion about the system does not erase the information duty.

Creating information, processing it, maintaining it, and operating the system are different activities. They may be performed by different parties. The report keeps the statutory language separate from the broader lifecycle language used in A-130 and cloud policy.

Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(1)(A)(i)–(ii), (b). Read source
- A-130: Managing Information as a Strategic Resource — §6(a)(1); §10(22)–(23); Appendix I §5(r). Read source

Control helps define responsibilities. It is not an exemption.

The tenant is often where an agency manages users, permissions, content, and configuration. Provider administrators, storage, backups, platform software, and physical facilities can still protect or expose that information. Those dependencies need an accountable treatment even when the agency cannot configure them.

NIST expressly discusses systems partly or entirely outside an authorizing organization's direct control. It allows separate boundaries, inherited controls, and external services. It does not turn the edge of the agency's administrative console into the edge of the agency's legal responsibility.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — §2.5 and footnote 42, pp. 17–18; Appendix G, pp. 159–161. Read source
- NIST SP 800-18 Revision 2 — §3.2, Authorization Boundary Description and System Component Inventory, pp. 19–21. Read source

The provider does not become an agency

OMB said this clearly in its 1993 A-130 analysis: defining government information broadly did not give every contractor or grantee the agency's own information-management responsibilities. Agreements matter. That is a distinction about who bears which duty, not a finding that commercially sold processing is outside federal security policy.

The right scope is the relevant information, service, supporting components, and obligations. There is no general rule that every unrelated corporate system must receive an agency authorization. There is also no general rule that provider-controlled components can be ignored.

Sources and exact locations

- A-130: Transmittal 1 — Appendix IV, §3, Analysis of §6: Government Information. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h)(1)–(2). Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G, pp. 157–161. Read source

Risk management works inside the applicable rules

The agency must understand risk and select protections proportionate to harm. That part of the hypothesis is right. But accepting risk is not a general power to waive a statute, a binding standard, a required contract clause, or an applicable cloud authorization requirement.

Where an external provider offers limited assurance, NIST describes compensating controls, accepting greater risk, choosing another provider, or not obtaining the service. Those are risk-management options; they do not decide which legal requirements can be set aside.

Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(1), (b)(2). Read source
- FIPS 200: Minimum Security Requirements — §§2–3. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G, p. 160. Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III, Scope of FedRAMP, p. 5. Read source

Handling information is not the same question as operating a system

The nouns and verbs matter. Read each phrase with its object, responsible actor, and legal source.

Information

What is collected or maintained for the agency?

FISMA §3554(a)(1)(A)(i)

Information systems

What is used or operated by or for the agency?

FISMA §3554(a)(1)(A)(ii)

The terms in their own authorities

Authority and object	Wording, condensed	What it does
FISMA: the information duty Information	Collected or maintained by or on behalf of an agency	The agency head must provide protection commensurate with risk. This limb does not require first declaring the recipient's entire system a federal system. Sources and exact locations • 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(1)(A)(i). Read source
FISMA: the system duty Information systems	Used or operated by an agency or by a contractor of an agency or other organization on behalf of an agency	The statute says "used or operated," not only "operated." It also requires an agency-wide security program covering systems supporting agency operations and assets.

Authority and object	Wording, condensed	What it does
		Sources and exact locations • 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(1)(A)(ii), (b). Read source
A-130: what information is federal Information in any medium	Created, collected, processed, maintained, disseminated, disclosed, or disposed of by or for the Federal Government	This definition identifies the information. It is not, on its own, a definition of a federal information system or a command to regulate every holder as an agency. Sources and exact locations • A-130: Managing Information as a Strategic Resource — §10(22)–(23). Read source
A-130: agency protection Information and information systems	Created, collected, processed, stored, transmitted, disseminated, or disposed of by or on behalf of the agency	The circular makes agency security responsibilities explicit across the lifecycle and includes information on behalf of agencies in contractor and cloud environments. Sources and exact locations • A-130: Managing Information as a Strategic Resource — Appendix I §3(b)(2); §4(j); §5(r). Read source
CUI rule: acting on behalf Activities of a non-executive-branch entity	Uses or operates a system, or maintains or collects information, for processing, storing, or transmitting federal information; those activities are not incidental to another product or service	Within this rule, outsourced information processing can be federal-system work. It expressly includes systems serving government and private customers. Do not export this definition to every statute without checking. Sources and exact locations • 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.4(hh); 2002.14(h). Read source

Authority and object	Wording, condensed	What it does
FedRAMP policy: covered cloud services Cloud products and services	Create, collect, process, store, or maintain federal information on behalf of an agency	These verbs set the program's cloud-service scope, subject to listed exclusions. They do not rewrite the words of FISMA or make every federal system a FedRAMP service. Sources and exact locations • Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III, p. 5. Read source
Privacy Act: a specific contractual trigger A system of records about individuals	Operation, by or on behalf of the agency, to accomplish an agency function	The agency must cause the Act's requirements to apply when contracting for this operation, within its authority. This is a particular statutory trigger, not a rule for every design document or every private database. Sources and exact locations • 5 USC 552a — Records maintained on individuals — 5 USC 552a(a)(5), (m). Read source

Handling information and operating a system can overlap

An agency employee creates a design in a SaaS tool. The employee may supply the design decisions while the service processes and stores the resulting document. The provider can be doing information-processing work for the agency even though the agency did the creative work. The provider need not author the content to maintain it.

Conversely, a company may receive government information to deliver a different product or service. Under the CUI rule, receiving that information only incidentally to work other than processing services can leave the company's system nonfederal. CUI protection obligations can still apply. The work's purpose matters; ownership, payment, and the presence of a government user do not answer everything.

Sources and exact locations

- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.4(hh), 2002.14(h)(1)–(2). Read source
- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(1)(A). Read source
- SP 800-171 Rev. 3: Protecting CUI — §1.1, pp. 1–2. Read source

The phrases are connected, but not interchangeable

“Federal information” is a category of information. “On behalf of” describes a relationship or purpose in a particular authority. “Federal information system” identifies a covered system. “Authorization boundary” sets the scope of an authorization. “FedRAMP scope” identifies a program’s covered services. One label cannot safely substitute for the others.

For each transaction, ask two questions first: what information is being handled for the agency, and what system or service is being used or operated for it? Then ask which requirements reach each party and through what authority or agreement. This is an analytical sequence drawn from the sources, not a new legal test.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — §10(22)–(23). Read source
- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(1)(A). Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — §2.5. Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III. Read source

---

How the distinction developed

This history follows duties and definitions across different authorities. A later document does not automatically repeal an earlier rule or settle its meaning.

1974

Law

Congress addresses outsourced records about people

The Privacy Act required agencies contracting for operation of a system of records to cause its requirements to apply when the operation accomplishes an agency function. Congress supplied a specific contractual bridge. It did not simply make every private recipient of government information a federal agency.

Sources and exact locations

- Privacy Act, P.L. 93-579 — §3, adding 5 USC 552a(m). Read source
- 5 USC 552a — Records maintained on individuals — 5 USC 552a(m). Read source

---

1980–1985

Law and OMB policy

Information management extends beyond the agency's machines

The Paperwork Reduction Act assigned government-wide and agency information-management responsibilities. The first A-130 addressed information handled by or for government. Its analysis also recognized that program managers often depend on contracted technical services they do not directly control. Accountability for the program remained with the agency.

Sources and exact locations

- Paperwork Reduction Act of 1980 — 44 USC 3504–3506 as enacted. Read source
- A-130: initial circular — §6; Appendix IV, analysis of §8b(2)–(3), 50 FR 52749; PDF p. 307. Read source

---

1988

Law

The Computer Security Act covers contractor-operated systems

The Computer Security Act of 1987, enacted January 8, 1988, defined federal computer systems to include specified contractor-operated systems processing information to accomplish a federal function. It assigned standards work and required security planning for systems with sensitive information. Contractor operation was already part of the statutory picture before commercial cloud computing.

Sources and exact locations

- Computer Security Act of 1987, P.L. 100-235 — §3, adding NBS Act §20(d)(2); §§5–7. Read source

---

1993–2000

OMB policy

OMB says the agency's duties do not automatically become the contractor's

The 1993 analysis of "government information" explains that broad information coverage does not extend responsibility for implementing the circular beyond executive agencies. It points to differences in FOIA and copyright treatment and says contractor and grantee duties are not identical to agency duties except as made so in their agreements. The 1996 and 2000 texts retain that explanation.

Sources and exact locations

- A-130: Transmittal 1 — Appendix IV, §3, Government Information. Read source
- A-130: Transmittal 3 — Appendix IV, Government Information. Read source
- A-130 (2000), Appendix IV — §3, Government Information. Read source

1996

Law and OMB policy

Incidental equipment and adequate security answer different questions

Clinger–Cohen's information-technology definition excluded equipment a contractor acquires incidentally to a federal contract. That is a definition for the statute's IT-management framework, not a universal exemption for federal information placed on that equipment. The 1996 A-130 security appendix emphasized risk, management authorization, and controls for systems and major applications.

Sources and exact locations

- Clinger–Cohen Act in P.L. 104-106 — Division E, §5002(3), now 40 USC 11101(6). Read source
- A-130: Transmittal 3 — Appendix III, §§2–3. Read source
- A-130: Managing Information as a Strategic Resource — Appendix I §5(r). Read source

2000–2002

Law

Congress separates information duties from system duties

GISRA and the 2002 security legislation made agency-wide security programs central. The December 2002 FISMA text separately covered information collected or maintained by or on behalf of an agency and systems used or operated by an agency, its contractors, or other organizations on its behalf. It also covered support furnished by another agency, contractor, or other source. Those clauses are broader than a test of machine ownership.

Sources and exact locations

- GISRA in P.L. 106-398 — §1061, former 44 USC 3534. Read source
- Homeland Security Act of 2002, Title X — §1001, former 44 USC 3534. Read source
- E-Government Act / FISMA 2002 — Title III §301, former 44 USC 3544(a)–(b). Read source

2004–2011

OMB policy

Cloud use is treated as outsourced work, not a new escape from security

FIPS 199 and 200 supplied categorization and minimum-security standards. In its FY 2010 instructions, OMB included fully and partly outsourced services, including SaaS. Its example

of incidental equipment was a contractor's corporate HR or finance system that neither used agency information nor interconnected with an agency system. The 2011 FedRAMP memorandum introduced a reusable cloud assessment and authorization process.

Sources and exact locations

- FIPS 199: Security Categorization — §§2–3. Read source
- FIPS 200: Minimum Security Requirements — §§2–3. Read source
- M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management — Questions 36–38, printed pp. 13–15; PDF pp. 17–19. Read source
- Security Authorization of Information Systems in Cloud Computing Environments — Scope and agency responsibilities. Read source

---

2014

Law

FISMA preserves both limbs of the duty

The Federal Information Security Modernization Act reorganized federal security responsibilities while preserving the distinct information and system clauses. They now appear in 44 USC 3554(a)(1)(A)(i) and (ii). Section 3554(b) still requires a program for information and systems supporting agency operations and assets, including support provided or managed by outside sources.

Sources and exact locations

- Federal Information Security Modernization Act — §2, 44 USC 3554. Read source
- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)–(b). Read source

---

2015–2016

Public comments

The A-130 revision draws concerns about private services

OMB sought public comments in October 2015. EPIC's December submission raised privacy concerns about private social-media and cloud services receiving visitor data through government websites. That concern illustrates why agency duties and private data practices cannot simply be assumed identical. It is a commenter's position, not an adopted tenant-only exception. The 2016 availability notice announces the revised circular; it is not a complete response-by-response account of the public comments.

Sources and exact locations

- Request for Comments on Circular No. A-130, Managing Information as a Strategic Resource — 80 FR 64022, October 22, 2015. Read source

- Comments of the Electronic Privacy Information Center to OMB on Circular No. A-130 — §III, pp. 5–6. Read source
- A-130 2016 final notice — 81 FR 49689, July 28, 2016. Read source

---

2016

OMB policy

A-130 expressly includes fully and partly provided cloud services

Appendix I's discussion of FISMA applicability quotes the information and system duties and includes agency-hosted, outsourced, and cloud-based solutions. It also explains that agencies remain accountable when federal information is used in incidentally acquired contractor equipment. Section 4(j) directs agencies to address relevant nonfederal entities through contracts and other agreements, oversight, assessment, inventories, and incident procedures.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j); §5(r), printed pp. 25–26 / PDF pp. 62–63. Read source

---

2016

Regulation

NARA draws an explicit outsourcing–incidental distinction

The CUI final rule defines acting on behalf and distinguishes outsourced information processing from receiving federal information only incidentally to a different product or service. It expressly includes systems serving both government and private users in the federal-system branch. Its nonfederal branch prohibits treating such systems as agency systems and directs use of SP 800-171 for CUI confidentiality, subject to stated exceptions.

Sources and exact locations

- NARA CUI final rule and comment responses — 81 FR 63330–63331, responses; §§2002.4(hh), 2002.14(h); effective November 14, 2016. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.4(hh), 2002.14(h). Read source

---

2017–2023

Public comments

The boundary remains contested in acquisition rules

RAND asked DHS to adopt NARA's definition and distinguish incidental CUI handling from operating federal systems. In 2023, DHS said its rule did not federalize systems not operated for government, and separated its system-authorization requirements from broader CUI handling and incident duties. But DHS declined to adopt NARA's definition as the general

FISMA definition, arguing that OMB should resolve that wider question. This is an express disagreement about the reach of a definition, not proof that either agency silently adopted the other's view.

Sources and exact locations

- RAND comments on DHS safeguarding proposal — Comments 1–4, pp. 3–9. Read source
- DHS safeguarding final rule and comment responses — 88 FR 40563–40565; §II.B.7, Definitions, 40571; basic clause and Alternate I; effective July 21, 2023. Read source

---

2018–2026

NIST guidance

NIST develops a way to manage separate boundaries and shared controls

SP 800-37 Revision 2 describes external providers beyond direct agency control, separate authorizations, and inherited safeguards. SP 800-47 Revision 1 follows information before, during, and after exchanges. SP 800-171 Revision 3 addresses CUI in nonfederal systems and explicitly separates that work from information and systems handled on behalf of an agency. SP 800-18 Revision 2, published June 2026, makes external services, information flows, and control responsibilities part of system planning.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — §2.5; Appendix G. Read source
- NIST SP 800-47 Revision 1 — §§1–3. Read source
- SP 800-171 Rev. 3: Protecting CUI — §1.1. Read source
- NIST SP 800-18 Revision 2 — §3.2. Read source

2022–2026

Law and OMB policy

FedRAMP's scope is its own question

Congress established FedRAMP in law in 2022 and assigned OMB the task of specifying covered categories. M-24-15 replaced the 2011 memorandum in 2024. It covers certain cloud services handling information for agencies while listing exclusions. The retrieved 2026 program guidance further emphasizes agency use cases. A single-agency application may be outside this shared program while the cloud infrastructure beneath it remains within scope. Neither result ends the agency's FISMA responsibilities.

Sources and exact locations

- FedRAMP Authorization Act in P.L. 117-263 — §5921. Read source

- 44 USC 3614 — Roles and responsibilities of the Office of Management and Budget — 44 USC 3614(1)(A). Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III. Read source
- FedRAMP scope guidance, retrieved October 24, 2026 — Agency Use Case Indicators; Single Agency Systems. Read source

Five boundaries that should not be confused

A useful scope statement names all five. They can overlap without being identical.

Information

Which data and activities does a duty cover?

Federal information can be public, sensitive, or controlled. Controlled unclassified information (CUI) needs a qualifying authority; ordinary unpublished government work is not automatically CUI. Confidentiality is only one objective: public information may still need integrity and availability protection.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — §10(22); Appendix I §3. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.4(h), (nn). Read source
- FIPS 199: Security Categorization — §3. Read source

System or service

What work is performed for the agency?

Identify the service and its purpose, who uses or operates it, and whether another regime supplies a specific test. A multi-customer service can perform work for an agency. The CUI rule expressly recognizes mixed government and private users.

Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)–(b). Read source

- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h)(1). Read source

---

Authorization

What is the scope of this risk decision?

The scope can be an application, a platform, a larger system, or common controls. Another authorized system can supply inherited protections. A boundary documents responsibility and dependencies; it does not amend a statute.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — §§2.3–2.5; Appendix G. Read source
- NIST SP 800-18 Revision 2 — §3.2. Read source

Implementation

Who configures, assesses, and monitors each safeguard?

A tenant administrator may manage accounts while the provider manages hardware, hypervisors, backups, and support access. Agreements, assessments, monitoring, and inherited controls can address this division. Each control still needs an identified owner.

Sources and exact locations

- SP 800-53 Rev. 5: Security and Privacy Controls — SA-9, External System Services; CA-3, Information Exchange; AC-20, Use of External Systems. Read source
- NIST SP 800-18 Revision 2 — §3.2, Control Implementation Details. Read source

---

Provider enterprise

Which other business systems actually matter?

The whole corporation is not automatically the authorized service. But a shared identity service, deployment system, support console, or backup store may affect the federal information. Analyze access and dependency, rather than excluding a component merely because the provider owns it.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G. Read source

- SP 800-53 Rev. 5: Security and Privacy Controls — SA-9; SC-7, Boundary Protection. Read source
- SP 800-171 Rev. 3: Protecting CUI — §1.1, component scope and separate security domains. Read source

Follow the information from creation to disposal

The same document can move through several systems and several legal regimes. These questions help keep the duties attached to the right activity.

1 Create and collect

An employee creates a design; a form collects responses.

Determine the agency purpose, the information involved, and authority to collect it. Collection from the public may trigger PRA review; personally identifiable information can trigger privacy analysis. Creating a design does not by itself trigger every one of those rules.

Sources and exact locations

- 44 USC 3506 — Federal agency responsibilities — 44 USC 3506(c). Read source
- 5 USC 552a — Records maintained on individuals — 5 USC 552a(e), (m). Read source
- A-130: Managing Information as a Strategic Resource — §5; Appendix II. Read source

2 Process and store

The application renders designs and keeps versions, comments, and copies.

Follow the information into provider storage, backups, support access, and subprocessors. Identify who implements protections. An agency-owned encryption key or tenant setting can reduce exposure without removing every service dependency.

Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)–(b). Read source

- SP 800-53 Rev. 5: Security and Privacy Controls — SA-9; SC-28, Protection of Information at Rest. Read source
- NIST SP 800-18 Revision 2 — §3.2. Read source

3 Transmit and exchange

A browser sends content across networks; an API shares it with another service.

Assess the endpoints, the exchange, and the transmission channel. Specify authorized recipients, authentication, protection in transit, and responsibilities after receipt. Exchanging information does not require placing every intervening network inside one authorization boundary.

Sources and exact locations

- NIST SP 800-47 Revision 1 — §§2–3. Read source
- SP 800-53 Rev. 5: Security and Privacy Controls — CA-3; SC-7; SC-8, Transmission Confidentiality and Integrity. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — §2.4; Appendix G. Read source

4 Use, share, and publish

Staff collaborate, export a design, or publish a finished page.

Check purpose and disclosure restrictions independently from system authorization. Permission to use a secure service does not authorize every disclosure. Public release also does not make integrity or availability irrelevant.

Sources and exact locations

- 5 USC 552a — Records maintained on individuals — 5 USC 552a(b). Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.16, 2002.18. Read source
- FIPS 199: Security Categorization — §3. Read source

5 Retain and retrieve

Versions and comments may document agency decisions.

Determine which materials are federal records and how the agency will retrieve, preserve, search, and transfer them. Outsourced storage does not remove records duties. FOIA expressly includes qualifying records maintained for an agency by a records-management contractor; it does not make every company record an agency record.

Sources and exact locations

- 44 USC 3301 — Federal records — 44 USC 3301. Read source
- NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments — NARA Bulletin 2010-05, questions 6–8. Read source
- 5 USC 552 — FOIA — 5 USC 552(f)(2)(B). Read source

---

6 Return and dispose

The agency ends the subscription or replaces the service.

Plan export, legal holds, retention schedules, deletion, backup handling, and incident evidence before exit. Closing an account is not proof that all required records were retained or every provider copy was destroyed.

Sources and exact locations

- NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments — Questions 6–8. Read source
- NIST SP 800-18 Revision 2 — §3.2, System Operational Status; SP 800-37 Task M-7. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(f). Read source

---

Compare the examples

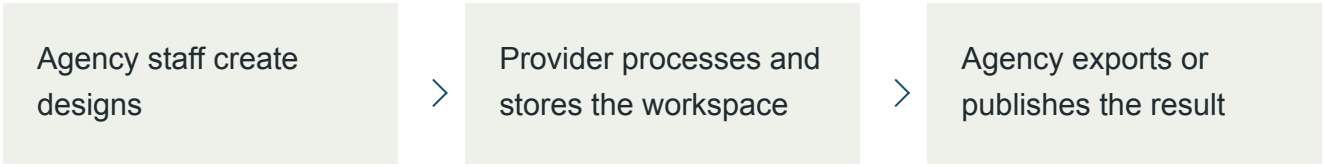
These are source-based illustrations with stated assumptions. They are not findings about a vendor's actual offering or a substitute for an agency's decision.

Design work in Figma

Assumptions. Agency staff use a commercial design workspace for website layouts. The provider stores designs and comments. No claim is made about any actual Figma offering,

contract, authorization, or security architecture.

Information and service relationships



The fact that it is commercial SaaS does not settle “on behalf of.”

The agency creates the substantive content; the service processes and maintains it. That can be information handling for the agency even though the agency does not operate the provider’s platform. In the CUI framework, a service whose job is information processing is different from receiving information merely incidentally to an unrelated service.

Simple website layouts may carry little confidentiality risk. That does not prove the service is out of scope: unreleased plans, research notes, user data, access credentials, or deployment integrations change the facts. A tenant can allocate user-management duties while provider controls remain relevant.

For an agency-approved public or nonsensitive collaboration use, the retrieved FedRAMP guidance supplies examples of exclusions that may be relevant. Applying one requires a use-case analysis; the report does not equate Figma with an expressly excluded product. Even an excluded use can leave security, privacy, records, and appropriate-use duties.

Agency	Purpose, information classification, authorized use, accounts, sharing, records, and the risk decision.
Provider under the applicable agreement	Service operation, platform protections, relevant support access, incident cooperation, retention and return commitments.
Boundary to examine	Workspace plus the service components and external dependencies that process or protect its content; not automatically the whole company.

What could change the answer?

A public workshop board with no sensitive content is different from a private design repository integrated with agency identity and production deployment. Copying CUI or personal data into the workspace requires a fresh analysis.

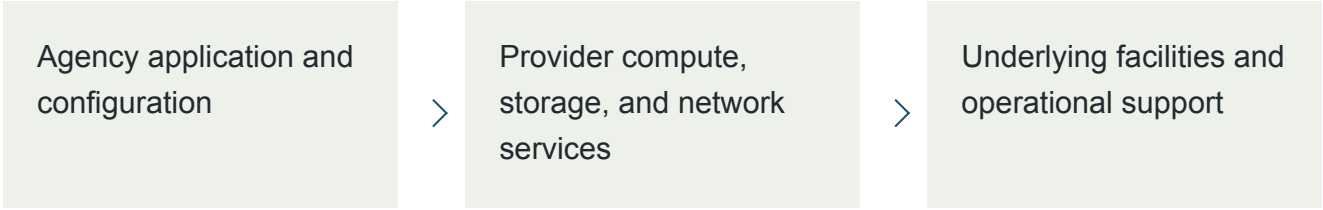
Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(1)(A). Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h). Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III. Read source
- FedRAMP scope guidance, retrieved October 24, 2026 — Social Media & Communications; Agency Use Case Indicators. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G. Read source

An agency application on AWS

Assumptions. The agency manages an application and virtual resources on commercial IaaS. AWS is an illustration of the service model, not a finding about any region, product, contract, or current authorization.

Information and service relationships



The agency workload and the infrastructure can have separate boundaries and connected responsibilities.

The agency can operate its application while the provider operates infrastructure that processes and stores agency information. The presence of an agency-controlled tenant does not mean the infrastructure performs no work on its behalf.

An application-only authorization may inherit protections from its host. The agency must identify which protections are inherited, what evidence supports them, and what it still implements. A host authorization does not authorize every application, configuration, integration, or use of information.

The provider's service boundary can include shared components relevant to confidentiality, integrity, and availability without embracing every corporate function or other customer's workload. The exact boundary follows the offering and its architecture.

Agency	Application code, workload configuration, permissions, data, application safeguards, and risk acceptance.
Infrastructure provider	The defined infrastructure service and its provider-implemented safeguards; details depend on the offering.
Boundary to examine	The application authorization, host-service authorization, inherited controls, and connections between them.

What could change the answer?

Adding a managed database, support access path, third-party backup service, or a different region can change the applicable service scope and evidence.

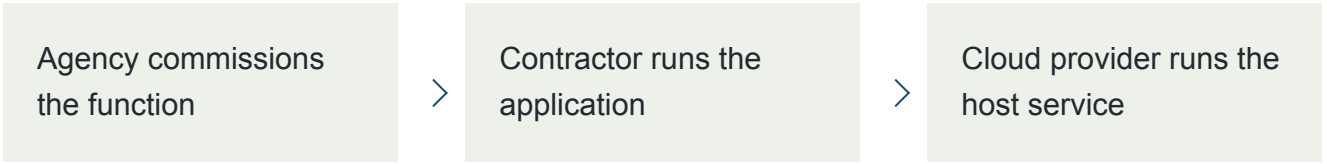
Sources and exact locations

- SP 800-145: The NIST Definition of Cloud Computing — §2, IaaS definition. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G, pp. 159–161. Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III. Read source
- NIST SP 800-18 Revision 2 — §3.2. Read source

A contractor builds and runs the agency's application

Assumptions. A contract expressly requires a company to build and operate an agency application on commercial cloud infrastructure. The application serves one agency and is not itself a reusable shared offering.

Information and service relationships



Subcontracting the infrastructure does not end the contractor's work on behalf of the agency.

The operating contract is strong evidence of agency-purpose system operation. The application may be a federal system even though both its operator and its infrastructure provider are private. The agency must arrange responsibilities across both layers.

M-24-15 excludes certain single-agency systems from FedRAMP. That program exclusion can apply to the custom application without excluding the host cloud service. It also does not exempt the custom system from agency security authorization or other applicable duties.

A development-only contract has different facts: delivering code is not the same as operating a production system. The developer's internal business tools need their own analysis of information, access, contractual requirements, and any incidental processing.

Agency	Mission, requirements, oversight, information duties, authorization, and applicable contracting terms.
Application contractor	Agreed development and operational responsibilities, application controls, incident duties, and host integration.

Cloud provider	Host-service protections and evidence; the contractor must account for what the application inherits.

What could change the answer?

Selling the same application as a multi-agency SaaS offering changes the FedRAMP scope question. Removing operation from the contract changes the system-role analysis.

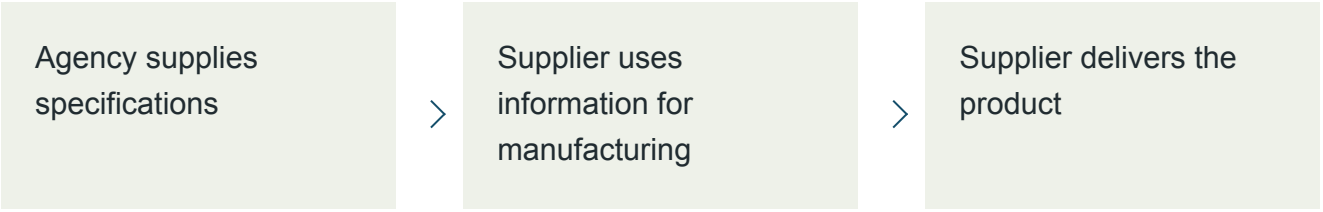
Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)–(b). Read source
- A-130: Managing Information as a Strategic Resource — Appendix I §4(j). Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III, exclusion 1. Read source
- FedRAMP scope guidance, retrieved October 24, 2026 — Single Agency Systems. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G. Read source

A company uses agency information to deliver another service

Assumptions. A supplier receives government specifications to manufacture a product. Its internal system supports that work; the agency has not outsourced an information-processing service to it.

Information and service relationships



A nonfederal system can still carry enforceable information-protection duties.

The CUI rule explicitly distinguishes information received only incidentally to a service or product other than processing services. Under that rule, the supplier's system is not made federal merely by holding the information.

If the specifications are CUI, the rule directs agencies to SP 800-171 for CUI confidentiality on nonfederal systems, with stated exceptions. The publication allows a defined security domain and covers components processing, storing, transmitting, or protecting CUI. It does not require protecting the entire business to an undifferentiated agency standard.

For covered federal contract information, FAR 52.204-21 can impose safeguards through a contract clause. Public information and simple payment transaction information are excluded from that clause's definition of federal contract information. These are specific limits, not a blanket exemption for commercial businesses.

Agency	Identify the information and applicable requirements; use lawful contract or agreement terms.
Supplier	Meet the applicable contract and information-protection obligations on its covered systems.
Boundary to examine	The components handling or protecting covered information, including dependencies; an isolated domain can reduce scope.

What could change the answer?

A contract to host, index, or process the agency's records changes the purpose: information processing is then the purchased service, not incidental support for manufacturing.

Sources and exact locations

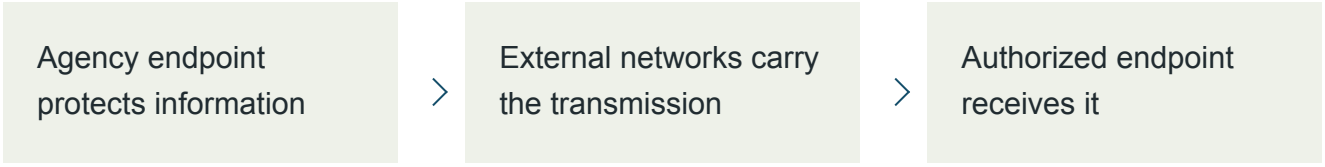
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h)(2). Read source
- SP 800-171 Rev. 3: Protecting CUI — §1.1. Read source

- FAR 52.204-21, November 2021 clause; FAC 2026-01 — FAR 52.204-21(a)–(c). Read source

Agency information crosses the internet

Assumptions. Agency endpoints exchange information over public networks. No single operator runs “the internet,” and ordinary transit is distinguished from a separately purchased managed network or cloud service.

Information and service relationships



A network dependency does not make the entire internet one federal system.

An information system is a discrete set of resources organized for information activities. An authorization covers a defined system and its responsibilities. Public networks may lie outside that boundary while still being part of the environment and a source of risk.

The agency protects the exchange through appropriate endpoint controls, authentication, encryption, connection rules, and agreements where applicable. SP 800-47 focuses on protection before, during, and after an exchange; it does not require ownership of the channel.

Do not turn this into “telecommunications can never be on behalf of government.” OMB’s outsourcing examples include telecommunications and managed services. A purchased managed network, a carrier contract, a cloud endpoint, and an arbitrary transit network can present different relationships.

Agency	Protect endpoints and exchanges, assess availability and interception risks, and authorize use.
Relevant service providers	Meet obligations for the specific services they supply; examine the actual contracts and legal regimes.

Boundary to examine	Defined endpoints and services, external connections, and risk controls —not the internet as a single owned asset.

What could change the answer?

Hiring a provider to run a private agency network or an application gateway adds a specific operated service to the analysis.

Sources and exact locations

- 44 USC 3502 — Definitions — 44 USC 3502(8). Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — §§2.4–2.5; Appendix G. Read source
- NIST SP 800-47 Revision 1 — §§2–3. Read source
- M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management — Question 38, printed pp. 14–15. Read source

---

What current NIST materials say—and what they cite

What today's NIST materials actually add

FIPS 199 classifies the potential impact of losing confidentiality, integrity, or availability. FIPS 200 establishes minimum security requirements for covered federal systems and points to control selection and tailoring. Neither gives a general "commercial SaaS" exemption. Public information can still need protection against alteration or interruption.

SP 800-37 Revision 2, §2.5, says system elements generally share direct management, but footnote 42 explains that management includes budgetary, programmatic, or operational authority and need not exclude intervening management. Appendix G then addresses external systems and providers, including cloud services wholly outside direct agency control. Read both passages together.

The same appendix permits application boundaries that inherit host protections. It also acknowledges limited visibility into providers and discusses assurance, compensating controls, risk acceptance, alternative providers, and declining a service. NIST is describing how to manage dependencies; it is not declaring them legally irrelevant.

Sources and exact locations

- FIPS 199: Security Categorization — §3. Read source
- FIPS 200: Minimum Security Requirements — §§2–3. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — §2.5, footnote 42; Appendix G, pp. 159–161. Read source

A boundary needs evidence and named responsibilities

SP 800-53 Revision 5 supplies controls for external system services (SA-9), use of external systems (AC-20), information exchange (CA-3), boundary protection (SC-7), and transmission confidentiality and integrity (SC-8). These are different tasks. Merely drawing a tenant box does not satisfy them.

The NIST publication page identifies Release 5.2.0, issued in August 2025, as the later control-catalog release. The older PDF in this site remains a dated source. The listed release changes do not replace the external-service and boundary concepts discussed here.

SP 800-18 Revision 2 replaced Revision 1 in June 2026. Its system-plan elements call for an authorization-boundary description, information-flow diagrams, external services, component inventory, inherited controls, and implementation responsibilities. Its references include FISMA, A-130, SP 800-37, and SP 800-53. The technical model links back to those authorities; it does not create a new private-sector regulator.

Sources and exact locations

- SP 800-53 Rev. 5: Security and Privacy Controls — AC-20; CA-3; SA-9; SC-7; SC-8. Read source
- NIST publication status: SP 800-53 Revision 5 / Release 5.2.0 — Planning Note, August 27, 2025. Read source
- NIST SP 800-18 Revision 2 — §3.2; References. Read source
- NIST publication status: SP 800-18 Revision 2 — Publication history, June 30, 2026. Read source

SP 800-171 describes a different branch

Revision 3 provides recommended requirements for protecting CUI confidentiality in nonfederal systems. Section 1.1 excludes the on-behalf information and system activities described in its footnote 8, which directs readers to agency requirements under FISMA. The publication points to the CUI regulation and derives its requirements from SP 800-53.

It allows organizations to isolate CUI components in a separate security domain and limits its requirements to components processing, storing, transmitting, or protecting CUI. This supports proportionate technical scope. It does not prove that every cloud tenant belongs in the nonfederal branch.

A NIST revision's publication date is not automatically the date a contract must change. Check the regulation, incorporated edition, contract, and transition terms. Likewise, the CUI rule's definition must be read within that program; DHS's 2023 response explicitly cautions against treating it as the final government-wide meaning of FISMA.

Sources and exact locations

- SP 800-171 Rev. 3: Protecting CUI — §1.1 and footnote 8; References. Read source
- NIST publication status: SP 800-171 Revision 3 — Publication history. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.2; 2002.14(h). Read source
- DHS safeguarding final rule and comment responses — §II.B.7, 88 FR 40571. Read source

---

Test the hypothesis against the sources

The evidence supports limits on imposing agency duties across a private business. It does not support a general tenant-only or commercial-service exemption.

Only the agency-controlled tenant operates on behalf of government.

Not supported as a general rule.

What supports it

Separate boundaries and shared controls can limit the agency's implementation work.

What limits it

NIST expressly includes external systems outside direct control; the CUI rule includes multi-customer processing systems.

Practical conclusion

Define the service, dependencies, and responsibilities before assigning the boundary.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — §2.5; Appendix G. Read source

- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h)(1). Read source

---

Using a commercial service does not federalize the provider's whole business.

Supported, with qualifications.

What supports it

OMB distinguishes agency duties from contractor duties; nonfederal systems have a distinct CUI branch.

What limits it

Relevant shared components may still process, protect, or expose the information.

Practical conclusion

Scope the offering and information duties; do not equate the offering with the entire company.

Sources and exact locations

- A-130: Transmittal 1 — Appendix IV, Government Information. Read source
- SP 800-171 Rev. 3: Protecting CUI — §1.1. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G. Read source

---

The agency only needs to understand and accept the risk.

Incomplete.

What supports it

Risk-proportionate protection and authorization are central.

What limits it

Standards, regulations, OMB requirements, and contracts can prescribe safeguards or authorization requirements.

Practical conclusion

Document both the risk decision and satisfaction of applicable requirements.

Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)–(b). Read source
- FIPS 200: Minimum Security Requirements — §§2–3. Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III. Read source

---

Cloud subcontracting breaks the on-behalf relationship.

Not supported.

What supports it

The host and application may have separate responsibilities and authorizations.

What limits it

The agency-purpose application still runs for the agency; the host supplies another layer of service.

Practical conclusion

Trace the chain rather than stopping at the first commercial provider.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j), §5(r). Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G. Read source

---

If FedRAMP excludes a use, government information rules no longer apply.

Not supported.

What supports it

The program has express exclusions and use-case guidance.

What limits it

FISMA, privacy, records, and contractual duties have their own triggers.

Practical conclusion

Record the FedRAMP decision separately from other duties.

Sources and exact locations

- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III. Read source
- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554. Read source
- NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments — Questions 6–8. Read source

---

Evidence library

Each source keeps its own edition and authority. The source links open local originals or complete extracted text. Original HTML snapshots may retain publisher assets; this report has no network dependencies.

Download sources (JSON) · Sources (CSV) · Claim-to-source index

---

Law · 1974-12-31

Privacy Act, P.L. 93-579

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`e7ee29d2c9d09b077dc356a4583a4a008621dce40b0f23fd51e19b5368815d4a`

- Back to discussion — §3, adding 5 USC 552a(m)

Law · 1980-12-11

Paperwork Reduction Act of 1980

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`5af687ae7085e87b72357c4ef3969bfa4388bddb179c76363ec7d49759036299`

- Back to discussion — 44 USC 3504–3506 as enacted

OMB circular · 1985-12-12

A-130: initial circular

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Amended by Transmittals 1–4.

Retrieved 2026-10-10. SHA-256:
`c6c996a0a79cfbae6c9220153a4d019871ee22bf0930fd180c70055cffe7b784`

- Back to discussion — §6; Appendix IV, analysis of §8b(2)–(3), 50 FR 52749; PDF p. 307

Law · 1988-01-08

Computer Security Act of 1987, P.L. 100-235

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`2eb2c0cdd6d2bbf652b358266e98be07fdb2b52526554aded1f90bb0a5238fd0`

- Back to discussion — §3, adding NBS Act §20(d)(2); §§5–7

OMB circular · 1993-06-25

A-130: Transmittal 1

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical amendment; later editions contain further changes.

Retrieved 2026-10-10. SHA-256:
`b394b7885e2a250a20af528c2c032bc8a749987bc7346c0f3bf385f00b05e270`

- Back to discussion — Appendix IV, §3, Analysis of §6: Government Information
- Back to discussion — Appendix IV, §3, Government Information
- Back to discussion — Appendix IV, Government Information

OMB circular · 1996-02-08

A-130: Transmittal 3

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical consolidated text; amended in 2000 and replaced in 2016.

Retrieved 2026-10-10. SHA-256:
`906a73bd9b77740b0ed2bfc6f2201ec33363e2a04def3f3108fc7aecc146c4b6`

- Back to discussion — Appendix IV, Government Information
- Back to discussion — Appendix III, §§2–3

Law · 1996-02-10

Clinger–Cohen Act in P.L. 104-106

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`60ecc3db67b9a71474f8e11cb310d1d86f8246fc9df154b31f93801dbe786c7e`

- Back to discussion — Division E, §5002(3), now 40 USC 11101(6)

Law · 2000-10-30

GISRA in P.L. 106-398

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`931a74e24e0288af43250e5e5d32c5c456c119904c08a6da4d87cb2adc0e41f8`

- Back to discussion — §1061, former 44 USC 3534

OMB circular · 2000-11-28

A-130 (2000), Appendix IV

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`dec37813f1c79ee93e2cf259690af4243f274a6f4643bcdbe6b283d3692a5ca3`

- Back to discussion — §3, Government Information

Law · 2002-11-25

Homeland Security Act of 2002, Title X

Local original · Official / original publisher

Locations, provenance, and uses in this report

General effective date 60 days after enactment; compare the December 17 E-Government Act separately.

Retrieved 2026-10-10. SHA-256:
`e96e8b44905469d308187a78a906db5695ebb0b3c218575e55835c62526a0fd2`

- Back to discussion — §1001, former 44 USC 3534

Law · 2002-12-17

E-Government Act / FISMA 2002

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`1eec72dc1f004c04be63c78eb850321592881cbf10bca889301f109dc5c9650e`

- Back to discussion — Title III §301, former 44 USC 3544(a)–(b)

NIST guidance · 2004-02-01

FIPS 199: Security Categorization

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`73d19f05f71e30f378050f178aa3943c38790bbae56c07f2b5708c5a1a90242f`

- Back to discussion — §§2–3
- Back to discussion — §3
- Back to discussion — §3
- Back to discussion — §3

NIST guidance · 2006-03-01

FIPS 200: Minimum Security Requirements

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`107a9b9cdc8eccf37386aec28bbaf2dfaef5cfece17151ceabc3960423243a57`

- Back to discussion — §§2–3
- Back to discussion — §§2–3
- Back to discussion — §§2–3
- Back to discussion — §§2–3

OMB memorandum · 2010-04-21

M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Current applicability not assessed

Retrieved 2026-10-10. SHA-256:
`de73191abda2c3037a37d6ff60566a6dd72c9aacbeaa8f5337b1f7be467273d2`

- Back to discussion — Questions 36–38, printed pp. 13–15; PDF pp. 17–19
- Back to discussion — Question 38, printed pp. 14–15

Guidance · 2010-09-08

NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`c617280c8662418efa5fc3aeb4ac57e31edf64e062ce8eec016bf361875be094`

- Back to discussion — NARA Bulletin 2010-05, questions 6–8
- Back to discussion — Questions 6–8
- Back to discussion — Questions 6–8

NIST guidance · 2011-09-01

SP 800-145: The NIST Definition of Cloud Computing

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`7b0c1a9fdfc67218b8ba2098f448c100c27070db91736b3c87fed63bfa21d418`

- Back to discussion — §2, IaaS definition

Unnumbered memorandum · 2011-12-08

Security Authorization of Information Systems in Cloud Computing Environments

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Rescinded by M-24-15 (opening and concluding sections).

Retrieved 2026-10-10. SHA-256:
`1000dc126873b7d4831512434a5087d6991e7b02f73200a39d49e683ec068fbc`

- Back to discussion — Scope and agency responsibilities

Law · 2014-12-18

Federal Information Security Modernization Act

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`96ab24c78d410963ebb0bcd519dbe4b95ee800400c49ea4448e6d3f39c3eb917`

- Back to discussion — §2, 44 USC 3554

Notice · 2015-10-22

Request for Comments on Circular No. A-130, Managing Information as a Strategic Resource

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Official issuing or archival host

Retrieved 2026-10-23. SHA-256:
`60ad864505a08346fbe8ce1da82c748210a4f0ba61a64da2f46501cee090b588`

- Back to discussion — 80 FR 64022, October 22, 2015

Public comment · 2015-12-04

Comments of the Electronic Privacy Information Center to OMB on Circular No. A-130

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Primary commenter-hosted submission

Retrieved 2026-10-23. SHA-256:
`3b51b3a36fd035b9d923adc163b73c043961d022bc85700e9406ce26a02da114`

- Back to discussion — §III, pp. 5–6

OMB circular · 2016-07-28

A-130: Managing Information as a Strategic Resource

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

2016 revision; later laws and memoranda also apply.

Retrieved 2026-10-10. SHA-256:
`f1a2e73a1063eab7d83da2a3bfa810f3aaebc9a6ef8e9d264ffc57ccd02152e6`

- Back to discussion — §6(a)(1); §10(22)–(23); Appendix I §5(r)
- Back to discussion — §10(22)–(23)
- Back to discussion — Appendix I §3(b)(2); §4(j); §5(r)

- Back to discussion — §10(22)–(23)
- Back to discussion — Appendix I §5(r)
- Back to discussion — Appendix I §4(j); §5(r), printed pp. 25–26 / PDF pp. 62–63
- Back to discussion — §10(22); Appendix I §3
- Back to discussion — §5; Appendix II
- Back to discussion — Appendix I §4(j)
- Back to discussion — Appendix I §4(j), §5(r)

OMB circular · 2016-07-28

A-130 2016 final notice

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`d7d35c2d1635f604b9e68594a710258ff21568c8477c0fb627744e36bd358939`

- Back to discussion — 81 FR 49689, July 28, 2016

Regulation · 2016-09-14

NARA CUI final rule and comment responses

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`f3e00594bf25f429b30f881900f3bec0fff2b70001d0b152902eb4b58fdc0a4f`

- Back to discussion — 81 FR 63330–63331, responses; §§2002.4(hh), 2002.14(h); effective November 14, 2016

Public comment · 2017-03-23

RAND comments on DHS safeguarding proposal

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Original acquired by inforegs from Regulations.gov; SHA-256 verified. Direct retrieval October 24 returned 403.

Retrieved 2026-10-23. SHA-256:
`b94bb7c8a4cfc506c67606cded3fb6ee7dca00598268f06e5fb47c14ed17ee97`

- Back to discussion — Comments 1–4, pp. 3–9

NIST guidance · 2018-12-01

SP 800-37 Rev. 2: Security and Privacy RMF

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`4f75e1136bb905a654f1bcd9eefefb4108f47597276ee5eec0688f6d96f6a01d`

- Back to discussion — §2.5 and footnote 42, pp. 17–18; Appendix G, pp. 159–161
- Back to discussion — Appendix G, pp. 157–161
- Back to discussion — Appendix G, p. 160
- Back to discussion — §2.5
- Back to discussion — §2.5; Appendix G
- Back to discussion — §§2.3–2.5; Appendix G
- Back to discussion — Appendix G
- Back to discussion — §2.4; Appendix G
- Back to discussion — Appendix G
- Back to discussion — Appendix G, pp. 159–161
- Back to discussion — Appendix G
- Back to discussion — §§2.4–2.5; Appendix G
- Back to discussion — §2.5, footnote 42; Appendix G, pp. 159–161
- Back to discussion — §2.5; Appendix G
- Back to discussion — Appendix G
- Back to discussion — Appendix G

NIST guidance · 2020-09-01

SP 800-53 Rev. 5: Security and Privacy Controls

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`fc63bcd61715d0181dd8e85998b1e6201ae3515fc6626102101cab1841e11ec6`

- Back to discussion — SA-9, External System Services; CA-3, Information Exchange; AC-20, Use of External Systems
- Back to discussion — SA-9; SC-7, Boundary Protection
- Back to discussion — SA-9; SC-28, Protection of Information at Rest
- Back to discussion — CA-3; SC-7; SC-8, Transmission Confidentiality and Integrity
- Back to discussion — AC-20; CA-3; SA-9; SC-7; SC-8

NIST guidance · 2021-07-20

NIST SP 800-47 Revision 1

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`3ba5248bab614da212440a1bcfe814f0068ef95ebc2d73025742bc78a89c865a`

- Back to discussion — §§1–3
- Back to discussion — §§2–3
- Back to discussion — §§2–3

Regulation · 2021-11

FAR 52.204-21, November 2021 clause; FAC 2026-01

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`da2a7d9150526fabb12e1869ebd82592b7fdebb1e01dd8081d93d401d6e4534d`

- Back to discussion — FAR 52.204-21(a)–(c)

Law · 2022-12-23

FedRAMP Authorization Act in P.L. 117-263

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`9e5d37dfa7d1282073c16f3dde21978078f62f58f9db36f4828e270e02de933f`

- Back to discussion — §5921

Regulation · 2023-06-21

DHS safeguarding final rule and comment responses

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`a5b720fb0fd7297d3756086f4e979a98060d8f8cefb74866aec6bd403ebb9fd5`

- Back to discussion — 88 FR 40563–40565; §II.B.7, Definitions, 40571; basic clause and Alternate I; effective July 21, 2023
- Back to discussion — §II.B.7, 88 FR 40571

Law · 2024 Code edition

5 USC 552 — FOIA

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`b1fad0a21337dc814f2f05e47f260dba90752af9f72c66c7b0323477183323de`

- Back to discussion — 5 USC 552(f)(2)(B)

Law · 2024 Code edition

44 USC 3301 — Federal records

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`ff9de8a95c4847cd61e115e1863f0a86fb766e66ffa29faae43bbb42623cb1ec`

- Back to discussion — 44 USC 3301

NIST guidance · 2024-05-01

SP 800-171 Rev. 3: Protecting CUI

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`3e4631df8b5d61f40a6e542b52779ef30ddbbfff31e09214fa94ad6e6f5e6d08`

- Back to discussion — §1.1, pp. 1–2
- Back to discussion — §1.1
- Back to discussion — §1.1, component scope and separate security domains
- Back to discussion — §1.1
- Back to discussion — §1.1 and footnote 8; References
- Back to discussion — §1.1

OMB memorandum · 2024-07-25

Modernizing the Federal Risk and Authorization Management Program (FedRAMP)

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Current applicability not assessed

Retrieved 2026-10-10. SHA-256:
`07aabe7fd0baa34e3c77b7c9537204c6ac1caff473e04af8dc7e40743c30250a`

- Back to discussion — §III, Scope of FedRAMP, p. 5
- Back to discussion — §III, p. 5
- Back to discussion — §III
- Back to discussion — §III
- Back to discussion — §III
- Back to discussion — §III
- Back to discussion — §III, exclusion 1
- Back to discussion — §III
- Back to discussion — §III

Regulation · 2025

32 CFR Part 2002: Controlled Unclassified Information (2025 edition)

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

official host

Retrieved 2026-10-23. SHA-256:
`7613256287fea6dadc38f7279cb2c63c377f808295e70fa9785660651236958a`

- Back to discussion — 32 CFR 2002.14(h)(1)–(2)
- Back to discussion — 32 CFR 2002.4(hh); 2002.14(h)
- Back to discussion — 32 CFR 2002.4(hh), 2002.14(h)(1)–(2)
- Back to discussion — 32 CFR 2002.4(hh), 2002.14(h)
- Back to discussion — 32 CFR 2002.4(h), (nn)
- Back to discussion — 32 CFR 2002.14(h)(1)
- Back to discussion — 32 CFR 2002.16, 2002.18

- Back to discussion — 32 CFR 2002.14(f)
- Back to discussion — 32 CFR 2002.14(h)
- Back to discussion — 32 CFR 2002.14(h)(2)
- Back to discussion — 32 CFR 2002.2; 2002.14(h)
- Back to discussion — 32 CFR 2002.14(h)(1)

NIST guidance · 2026-06-30

NIST SP 800-18 Revision 2

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`640f9124469f285fc39dbeffd59708c84043d1a6b64cc87988f31e7e98942371`

- Back to discussion — §3.2, Authorization Boundary Description and System Component Inventory, pp. 19–21
- Back to discussion — §3.2
- Back to discussion — §3.2
- Back to discussion — §3.2, Control Implementation Details
- Back to discussion — §3.2
- Back to discussion — §3.2, System Operational Status; SP 800-37 Task M-7
- Back to discussion — §3.2
- Back to discussion — §3.2; References

Publication status · 2026-10-24

NIST publication status: SP 800-18 Revision 2

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`6e9b69244d8347df4a1b6c2a70ba411afbafd55c14ea748e420c6279501878a6`

- Back to discussion — Publication history, June 30, 2026

Publication status · 2026-10-24

NIST publication status: SP 800-53 Revision 5 / Release 5.2.0

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`00c4e550ba1326976657136497711dc3f4dffc86e90f0d71052a3ebdc1b4d21c`

- Back to discussion — Planning Note, August 27, 2025

Publication status · 2026-10-24

NIST publication status: SP 800-171 Revision 3

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`a3cdded2f973b252b68e2082f794626a425c9bdbbf31ce7afb4a8ff1d90bf595`

- Back to discussion — Publication history

Program guidance · Retrieved 2026-10-24

FedRAMP scope guidance, retrieved October 24, 2026

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Official FedRAMP/2026 repository, default branch snapshot. Retrieval date is not issuance date.

Retrieved 2026-10-24. SHA-256:
`a338ad564d8c1eb0a6929e79df24d864bb214e66e12e54a2ae708ef18a9e26f7`

- Back to discussion — Agency Use Case Indicators; Single Agency Systems
- Back to discussion — Social Media & Communications; Agency Use Case Indicators
- Back to discussion — Single Agency Systems

Law · Through 2026-09-30

44 USC 3554 — Federal agency responsibilities

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

- Back to discussion — 44 USC 3554(a)(1)(A)(i)–(ii), (b)
- Back to discussion — 44 USC 3554(a)(1), (b)(2)
- Back to discussion — 44 USC 3554(a)(1)(A)(i)
- Back to discussion — 44 USC 3554(a)(1)(A)(ii), (b)
- Back to discussion — 44 USC 3554(a)(1)(A)
- Back to discussion — 44 USC 3554(a)(1)(A)
- Back to discussion — 44 USC 3554(a)–(b)
- Back to discussion — 44 USC 3554(a)–(b)
- Back to discussion — 44 USC 3554(a)–(b)
- Back to discussion — 44 USC 3554(a)(1)(A)
- Back to discussion — 44 USC 3554(a)–(b)
- Back to discussion — 44 USC 3554(a)–(b)
- Back to discussion — 44 USC 3554

Law · Through 2026-09-30

44 USC 3502 — Definitions

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

- Back to discussion — 44 USC 3502(8)

Law · Through 2026-09-30

44 USC 3506 — Federal agency responsibilities

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

- Back to discussion — 44 USC 3506(c)

Law · Through 2026-09-30

44 USC 3614 — Roles and responsibilities of the Office of Management and Budget

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

- Back to discussion — 44 USC 3614(1)(A)

Law · Through 2026-09-30

5 USC 552a — Records maintained on individuals

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`f8e6aa5def8854f8d2b1702eccd36962b92080d6212b64c543fa72f1ae1b209a`

- Back to discussion — 5 USC 552a(a)(5), (m)
- Back to discussion — 5 USC 552a(m)
- Back to discussion — 5 USC 552a(e), (m)
- Back to discussion — 5 USC 552a(b)

Coverage, source dates, and open questions

- This is a civilian, unclassified analysis. National security systems, classified information, DoD contracting, CMMC, sector-specific secrecy laws, and every agency supplement are not comprehensively analyzed.
- The report distinguishes issuance, effective dates, source editions, and retrieval dates. It does not reconstruct every intervening amendment or establish the original intent of Congress from policy documents written later.
- The law links use the site's OLRC release 119-118, through September 30, 2026. FOIA and records-definition additions use the 2024 Code. The CUI text is the 2025 annual CFR. October 24 attempts to retrieve current OLRC and eCFR text failed. These limits prevent a claim that every legal change through October 24 has been verified.
- NIST publication status and the official FedRAMP scope source were checked on October 24, 2026. The FedRAMP source is program guidance and must be read alongside M-24-15. Its examples do not amend FISMA. The current-law discussion states the result supported by the identified editions, with the currency limits above.
- Selected public comments are preserved as comments. EPIC and RAND do not speak for the government. The complete 2015 A-130 comment docket and a provision-by-provision OMB response were not recovered in this research. No causal claim is made that a particular comment produced final wording.
- Inforegs supplied discovery and exact passage retrieval. Its semantic backfill was incomplete, so searches used lexical retrieval; results were not exhaustive. Original documents, surrounding provisions, and official publication pages were checked separately. A missing search hit is not evidence that no rule existed.
- Figma and AWS illustrate service models under stated assumptions. This report does not inspect their private agreements, actual system boundaries, or current certification status. It offers a source-based analysis, not an agency authorization or a vendor compliance verdict.

What still needs an agency-specific answer

The actual information, purpose of the service, applicable contract, agency policies, system architecture, provider access, and available assurance determine the result for a real purchase. Where authorities differ in scope, record the reason for the chosen interpretation instead of treating a convenient definition as universal.

Research and review were performed in this chat, including a separate self-review. No independent legal review or vendor assessment was performed. Research refreshes are manual.